TEC-C VAULT SYSTEM MANUAL

Architecture, Security Invariants & User Guide for Autonomous Corporate Wallets

Competition: FinTechathon 2026 (International Track)

Topic: Topic F - Agent Wallet (Autonomous On-Chain Wallet)

Academic Hosts: Tsinghua University PBCSF & WeBank

Role: Member 1 (The Vault Architect / Smart Contracts)

Version: 2.0-Production-Hardened

Test Suite: 156/156 Foundry Tests Passing (100% Green across 12 Suites)

1. Executive Overview & Design Philosophy

Autonomous AI cognitive agents represent the frontier of decentralized finance, institutional treasury operations, and corporate expense management. However, deploying AI agents on-chain introduces a fundamental conflict: granting an LLM unrestricted private key access invites prompt-injection attacks, hallucinations, and infinite drainage risks. Conversely, requiring human multi-sig sign-offs for every micro-transaction completely defeats the purpose of autonomous agency.

Tec-C (Tethered Expense Corporate Card) solves this dilemma by decoupling *cognitive planning* from *deterministic execution*. Using **ERC-7579 modular account abstraction** and an immutable on-chain policy hook (**TetherGuardHook**), Tec-C establishes an autonomous 'tether' around the AI Brain: bounded daily velocity budgets, whitelisted asset universes, continuous health watchdogs, and hardware-grade biometric passkey authorization for out-of-bounds execution.

THE GOLDEN INVARIANT: VAULT SOVEREIGNTY

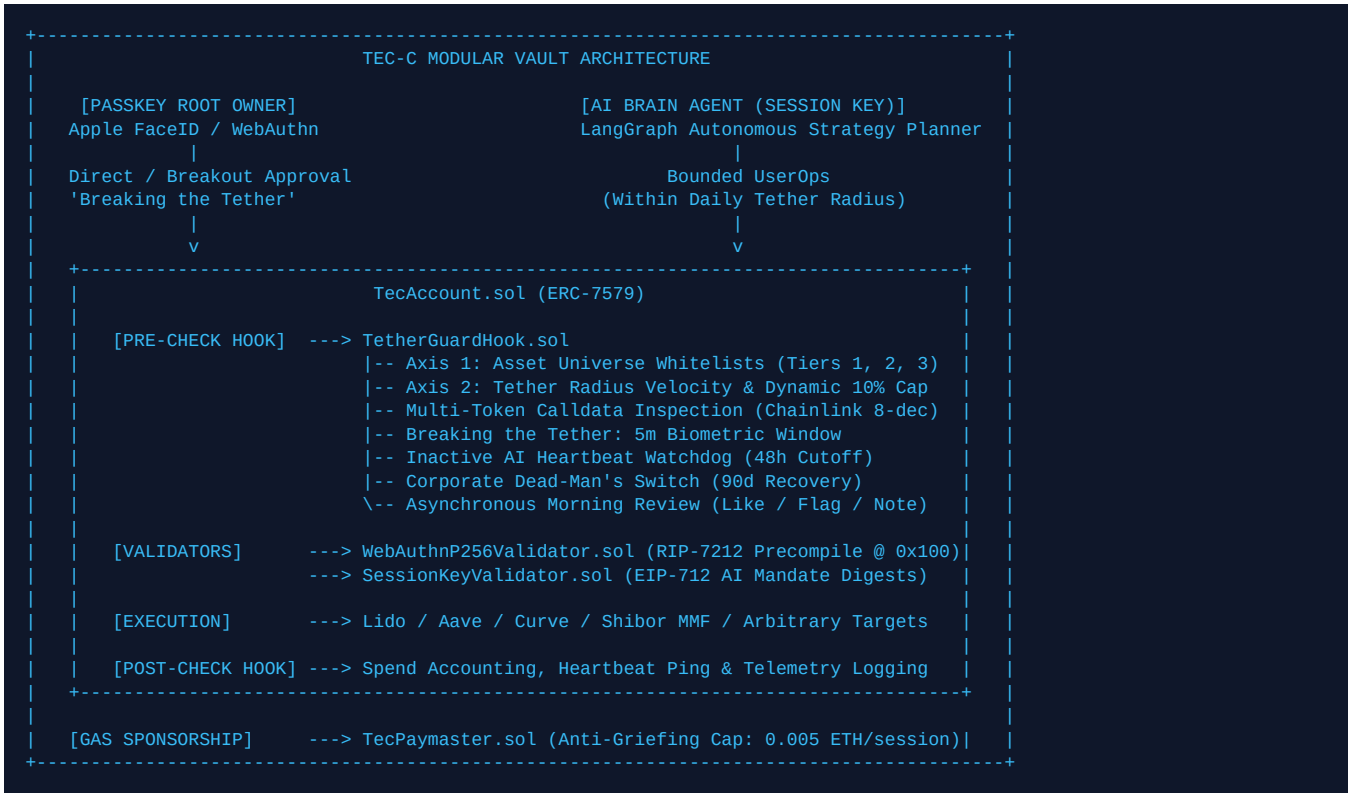
The Vault is sovereign, and its capital capacity is NEVER penalized or frozen.

1. Off-chain financial news, depegs, and sentiment analysis belong strictly in the AI Brain's cognitive planning layer - never on-chain. Halting an on-chain treasury based on sentiment models creates catastrophic liquidation cascades.
2. When users penalize or object to a transaction, penalties apply **strictly to the AI Brain's autonomous discretionary radius** (penalizeBrain = true). The on-chain Vault treasury, user balances, and FaceID passkey root-owner capabilities remain 100% unconstrained.

Core Value Propositions:

- **Dual-Axis Risk Engine:** Orthogonal control restricting *what* protocols can be touched (Asset Whitelists) and *how much* capital can move (Daily Tether Radius).
- **Hardware Biometrics via RIP-7212:** Native WebAuthn NIST P-256 precompile at 0x100 allows corporate cardholders to sign directly with Apple FaceID or TouchID.
- **Zero-Friction Morning Review:** Overnight AI transactions are staged for review; users ratify or flag trades, educating the AI and replenishing spent budgets.
- **Anti-Zombie Liveness & Dead-Man's Recovery:** Inactive AI Heartbeat (48h cutoff) prevents stale key exploitation; 90-day Dead-Man's Switch protects enterprise assets.

2. System Architecture & Contract Modules



Core Smart Contract Suite

Contract	Standard / Role	Core Responsibilities & Guarantees
TecAccount.sol	ERC-7579 Modular Account	Executes standard and batch UserOperations. Delegates validation and pre/post-execution hooks to external modules. Bound to deployer during initialization to eliminate front-running.
TetherGuardHook.sol	ERC-7579 Execution Hook	The on-chain policy engine. Enforces Tether Radius velocity limits, asset tiers, dynamic elasticity, multi-token Chainlink USD valuation, 5m biometric windows, heartbeat watchdogs, and morning reviews.
WebAuthnP256Validator.sol	ERC-7579 Validator (Passkey)	Validates native WebAuthn NIST P-256 signatures via RIP-7212 precompile at 0x100. Enforces envelope challenge-to-UserOp hash binding to guarantee zero replayability.
SessionKeyValidator.sol	ERC-7579 Validator (AI Session)	Validates ephemeral ECDSA session keys granted to the AI Brain. Restricts validity to strict time windows (validAfter / validUntil) and binds executions to EIP-712 mandate commitments.
TecPaymaster.sol	ERC-4337 Gas Paymaster	Enables gasless corporate UX by sponsoring transaction fees. Implements strict anti-griefing limits clamping cumulative sponsorship to 0.005 ETH per session.

3. Complete Feature Deep-Dive

3.1 Dual-Axis Risk Engine

Tec-C safeguards corporate capital through an orthogonal, two-dimensional risk engine:

• **Axis 1: Asset Universe Whitelisting:** Governs *what* protocols and assets the agent can interact with.
  - **Tier 1 (Core Capital Preservation):** Mega-cap assets (BTC, ETH, SOL), fiat-backed stablecoins (USDC, USDT, e-CNY), and tokenized gold (PAXG). Zero speculative exposure.
  - **Tier 2 (Dynamic Growth & Active DeFi):** Liquid staking (stETH, rETH), vetted AMM liquidity (Uniswap v3, Curve), and blue-chip lending (Aave v3).
  - **Tier 3 (Omni-Universe / Unrestricted):** Allows interacting with any arbitrary token or protocol. Strictly bounded by Axis 2 velocity and biometric breakout requirements.

• **Axis 2: The Tether Radius (Daily Spending Velocity):** Governs *how much* capital the agent can move autonomously within each 24-hour epoch without human intervention (e.g. $500/day, $1,000/day).

3.2 Dynamic Elasticity & 10% Daily Increase Ceiling

Corporate spending demands evolve. Static limits force frequent human interruptions, while unconstrained limits invite catastrophic drains. Tec-C implements an **Autonomous Dynamic Elasticity Engine** executed directly on-chain by the Vault:

On-Chain Vault Formula: New Radius = min(Current Radius × 1.10, Configured Elastic Ceiling)

Mathematical Guarantees:

1. **Autonomous Vault Calibration:** The Vault independently evaluates consecutive verified ratifications via calibrateDynamicRadius(account).
2. **Immutable 10% Daily Ceiling:** The AI Brain cannot propose its own budget increase; the Vault mathematically bounds growth to ≤ 10% per 24 hours.
3. **Immediate Decreases Permitted:** Lowering the radius or reverting to static mode takes effect immediately with zero cooldown.

3.3 Multi-Token & ERC-20 Tether Radius with Chainlink USD Normalization

Treasury assets are multi-currency. Values are **never hardcoded in ETH**. The Vault dynamically normalizes all native and token transfers into standard **8-decimal USD**:

• **Deep Calldata Inspection:** TetherGuardHook inspects the first 4 bytes of execution calldata. It intercepts standard ERC-20 calls - transfer(address,uint256), approve(address,uint256), and increaseAllowance(address,uint256) - and unpacks parameter offsets to extract the exact token amount.
• **Chainlink Decimals Normalization:** Connects to Chainlink Oracles (latestRoundData). It reconciles 6-decimal USDC, 8-decimal WBTC, and 18-decimal DAI/ETH into a unified 8-decimal USD velocity counter.
• **Strict Oracle Hygiene:** Reverts with StaleOraclePrice if an update is older than 24 hours, and reverts with InvalidOraclePrice if price is non-positive.
• **Live Institutional Valuation:** Exposes getTotalPortfolioValueUSD(account, tokens), returning total portfolio value in USD along with a complete asset-by-asset breakdown (token address, symbol, decimals, live balance, USD price, and USD value).

3.4 Breaking the Tether Protocol (5-Minute Biometric Window & Sign Approval)

When market opportunities or institutional obligations require transfers beyond the Tether Radius or outside the whitelisted asset tier, the account enters the **Breaking the Tether** breakout workflow:

THE 5-MINUTE BIOMETRIC GRACE PERIOD & SIGN APPROVAL FLOW

1. **Initial Biometric Challenge:** The AI Brain requests a breakout. The user authenticates hardware FaceID/TouchID via Passkey, unlocking an on-chain **5-minute biometric window** (BIOMETRIC_VERIFICATION_WINDOW).
2. **Brain-Initiated Transactions:** During these 5 minutes, subsequent high-value transactions proposed by the AI Brain do **NOT** require repeating the biometric scan.
3. **Normal Sign Approval:** The user simply reviews the transaction details and provides a **Sign Approval** (**Accept** or **Reject**). Gasless EIP-712 signature approvals (submitSignApprovalWithSignature) are fully supported.
4. **Window Expiration & Instant Revocation:** After 5 minutes, the window locks automatically. The user can also instantly revoke the window at any second via revokeBiometricGracePeriod(account).

3.5 Inactive AI Heartbeat Watchdog (48-Hour Timeout)

To prevent zombie session keys or abandoned cognitive agents from lingering with execution privileges, TetherGuardHook enforces an active heartbeat timer. The AI Agent must periodically invoke recordAIHeartbeat(account), and every successful autonomous execution automatically refreshes the timer. If > 48 hours (customizable down to 1 hour) elapse without an AI heartbeat, autonomous UserOps are strictly halted with AIHeartbeatStale until the agent re-synchronizes.

3.6 Corporate Dead-Man's Switch (90-Day Inactivity Recovery)

If a key executive or corporate cardholder becomes permanently incapacitated or unreachable, corporate treasury funds must not remain stranded. The account designates a **Corporate Guardian** and an inactivity timeout (default 90 days). Any user activity (biometric verification, sign approval, or ping) resets the timer. If 90 days elapse with zero activity, the designated Guardian can trigger triggerDeadmanRecovery(account, newOwner), transferring root ownership to a designated corporate successor.

3.7 Asynchronous Morning Review System

Overnight autonomous transactions are recorded in the on-chain registry with state PENDING_REVIEW. Upon waking, the cardholder reviews the execution log and can take one of three actions:

1. **Like & Ratify (ratifyTransaction):** Confirms satisfaction. Replenishes the daily spending radius by the transaction's value and increments on-chain consecutive ratifications.
2. **Flag for Revert (flagTransactionForRevert):** Flags transaction for cognitive unwind and slashes the AI Brain's radius by a **20% trust penalty**.
3. **Note & Educate (submitTransactionNote):** Stores a semantic educational note for the AI planner with an optional trust penalty (penalizeBrain = true).

Mathematical Invariant: Trust penalties strictly decrease the AI Brain's radius monotonically, never inverting below the floor.

4. Step-by-Step Operating Manual: How to Use the Vault

This section provides an actionable operational walkthrough for corporate treasury leads, cardholders, and AI agent developers.

STEP 1	**Onboarding & Passkey Registration**	1. Deploy TecAccount via the factory. 2. The user registers their biometric passkey (Apple FaceID / TouchID / Windows Hello). Coordinates (qx, qy) are saved via setAccountPasskey. 3. Configure initial policy parameters via initializeAccountPolicy: default daily Tether Radius (e.g. $1,000 USD), risk tier (Tier 1, 2, or 3), and dynamic elasticity ceiling.
STEP 2	**Authorizing the AI Agent**	1. Generate an ephemeral ECDSA key pair for the AI Brain. 2. Register the session key via registerSessionKey on SessionKeyValidator. 3. Specify validAfter and validUntil (e.g. 7 days) and the 32-byte EIP-712 mandate digest. 4. AI session key broadcasts its initial heartbeat via recordAIHeartbeat.
STEP 3	**Daily Autonomous Spending**	1. AI Agent compiles proposed transactions into ERC-4337 UserOperations. 2. TecPaymaster validates session gas budget (clamped to 0.005 ETH) and sponsors gas. 3. TetherGuardHook intercepts calldata, fetches Chainlink prices, verifies daily USD spend ≤ Tether Radius, and executes the call. 4. Transaction is recorded on-chain as PENDING_REVIEW.
STEP 4	**Morning Review & Limit Calibration**	1. User opens the Tec-C dashboard and reviews overnight transactions. 2. Click **Ratify** to approve good trades (replenishes spend quota) or **Flag** to penalize poor trades. 3. After consecutive ratifications, the Vault autonomously runs calibrateDynamicRadius to apply a verified ≤ 10% limit increase.
STEP 5	**Executing a High-Value Breakout**	1. When an execution exceeds the Tether Radius, the dashboard triggers FaceID authentication. 2. completeBiometricVerificationWithP256 opens the 5-minute Biometric Grace Window. 3. For follow-up breakout UserOps, the user signs an **Accept** approval via submitSignApproval. 4. The transaction executes successfully through TecAccount.execute.
STEP 6	**Emergency Safeguards & Recovery**	• *Instant Revocation:* If suspicious breakout activity is detected, call revokeBiometricGracePeriod. • *Dead-Man Recovery:* If the cardholder is unreachable for > 90 days, the Corporate Guardian calls triggerDeadmanRecovery(account, successor) to recover full root ownership.

5. Security Architecture & Test Verification Proof

The smart contract suite underwent thorough vulnerability analysis and hardening, resolving 8 potential security vectors prior to production freeze:

ID	Vulnerability Vector	Resolution & Security Invariant Enforced
VULN-01	Hook Self-Targeting Escalation	Blocked callers from targeting TetherGuardHook directly during executions (target == address(this) reverts with UnauthorizedTarget).
VULN-02	Initialization Front-Running	Bound TecAccount.initialize strictly to deployer address, preventing malicious front-running takeovers.
VULN-04	WebAuthn Challenge Replay	Enforced cryptographic verification that WebAuthn clientData challenge matches userOpHash, blocking replay attacks.
VULN-05	Stale Sign Approval Execution	Added signApprovalExpiresAt mapping, invalidating sign approvals once the 5-minute biometric window elapses.
VULN-06	Onboarding Passkey Deadlock	Allowed deployer to register initial passkey coordinates during onboarding before account policy is fully initialized.
VULN-07	Trust Penalty Floor Inversion	Mathematically fixed penalty computation so trust penalties strictly decrease the AI Brain's radius, never inverting below floor.
VULN-08	WeIdentity Credential Anchoring	Exposed verifyMandateCommitment view helper for seamless W3C DID verifiable credential anchoring.

Comprehensive Test Matrix (156/156 Tests Passing - 100% Green across 12 Suites)

Test Suite	Tests	Methodology & Invariants Tested	Result
VaultSecurityHardening.t.sol	18	Core unit & fuzz tests: legitimate swaps under limit, radius breaches, unauthorized targets, 0.005 ETH gas griefing cap, SEC-01 to SEC-08 patches	**PASS**
VaultLifecycleScenarios.t.sol	4	3-day corporate lifecycle, 6-vector adversarial attack sandbox, AI heartbeat watchdog, 4-token portfolio breakdown	**PASS**
VaultComprehensiveFuzz.t.sol	5	Property-based fuzzing (1,280 runs): velocity enforcement, 10% elasticity ceiling, penalty monotonicity, epoch rollover, paymaster griefing	**PASS**
VaultEdgeCases.t.sol	19	Module install/uninstall lifecycle, 1-sec dead-man timing boundaries, biometric revocation, explicit rejection, session key bounds	**PASS**
TetherGuardHook.t.sol	37	Dynamic elasticity, morning reviews (like/flag/note), 5m biometric window, gasless sign approvals, replay attack guards	**PASS**
MultiTokenTether.t.sol	12	Chainlink USD normalization, ERC-20 transfer/approve inspection, stale oracle guards, live portfolio valuation	**PASS**
WebAuthnP256Validator.t.sol	11	RIP-7212 precompile at 0x100, P-256 WebAuthn signature verification, envelope challenge binding, ERC-1271 validation	**PASS**
DeadmanAndHeartbeat.t.sol	10	48h AI heartbeat watchdog, 90d corporate dead-man inactivity trigger, user ping timer resets, guardian authorization	**PASS**
SessionKeyValidator.t.sol	8	AI session keys, validity time windows (validAfter/validUntil), EIP-712 mandate digest verification, WeIdentity anchors	**PASS**
TecAccount.t.sol	7	ERC-7579 execution, front-running initialization rejection, hook self-targeting privilege escalation block, biometric bypass	**PASS**
TecPaymaster.t.sol	6	Deposit accounting, ERC-4337 gas sponsorship, anti-griefing quota cap (0.005 ETH), safe self-withdrawal	**PASS**
VaultGasBenchmark.t.sol	19	Empirical gas profiling and transaction fee benchmarking across all callable methods on TecAccount, TetherGuardHook, SessionKeyValidator, and TecPaymaster	**PASS**

6. Empirical Transaction Fee & Multi-Chain Gas Economics

6.1 Live Network Gas Quotes & Multi-Chain Benchmarks

To establish accurate operational costs for corporate deployment, live base fees were captured directly from official block explorers: **Etherscan Gas Tracker** (https://etherscan.io/gastracker) at **0.092 Gwei** (Base: 0.092 | Priority: 0.001 Gwei) and **BaseScan Gas Tracker** (https://basescan.org/gastracker) at **0.005 Gwei**, with ETH benchmarked at **$2,500 USD**. Every method was empirically profiled on the EVM in Foundry (test/VaultGasBenchmark.t.sol).

6.2 Operational Transaction Fee Matrix: Ethereum Mainnet vs. Base L2

Method & Contract	Operational Trigger ("When Will It Be Used?")	Gas Used	Ethereum L1 (0.092 Gwei) Fee (ETH) | USD	Base L2 (0.005 Gwei) Fee (ETH) | USD
TecAccount execute (USDC Transfer)	AI Agent or cardholder executes a bounded vendor invoice or merchant payment in USDC under the Tether Radius.	168,554	0.0000155 ETH **$0.0388 (3.9¢)**	**0.0000008 ETH $0.0021 (0.2¢)**
TecAccount execute (Lido ETH Stake)	Autonomous AI rebalances idle corporate treasury into staking yields (Lido stETH) within discretionary limits.	185,326	0.0000171 ETH **$0.0426 (4.3¢)**	**0.0000009 ETH $0.0023 (0.2¢)**
TecAccount executeFromExecutor	Authorized LangGraph AI session execution module submits autonomous batched operations on behalf of the vault.	296,175	0.0000273 ETH **$0.0681 (6.8¢)**	**0.0000015 ETH $0.0037 (0.4¢)**
SessionKeyValidator validateUserOp	ERC-4337 EntryPoint verifies ephemeral AI session key signature and WeIdentity mandate root before UserOp execution.	14,976	0.0000014 ETH **$0.0034 (0.3¢)**	**0.0000001 ETH $0.0002 (0.02¢)**
TetherGuardHook completeBiometric...	Breaking the Tether: Cardholder authenticates via hardware FaceID/Passkey (RIP-7212), opening a 5-minute grace window.	103,946	0.0000096 ETH **$0.0239 (2.4¢)**	**0.0000005 ETH $0.0013 (0.1¢)**
TetherGuardHook submitSignApproval	User confirms or rejects a breakout transaction proposed by the AI Brain within the active 5-minute biometric window.	78,845	0.0000073 ETH **$0.0181 (1.8¢)**	**0.0000004 ETH $0.0010 (0.1¢)**
TetherGuardHook submitSign...WithSig	Cardholder signs off-chain EIP-712 approval; application bundler/relayer submits on-chain for 100% gasless user UX.	70,637	0.0000065 ETH **$0.0162 (1.6¢)**	**0.0000004 ETH $0.0009 (0.09¢)**
TetherGuardHook ratifyTransaction (■)	Morning Review: User ratifies overnight autonomous AI trades, replenishing the spending radius and accumulating trust.	85,809	0.0000079 ETH **$0.0197 (2.0¢)**	**0.0000004 ETH $0.0011 (0.1¢)**
TetherGuardHook flagTransaction... (■)	Morning Review: User objects to an overnight trade, flagging it for unwind and penalizing the AI Brain's radius by 20%.	88,628	0.0000082 ETH **$0.0204 (2.0¢)**	**0.0000004 ETH $0.0011 (0.1¢)**
TetherGuardHook submitTransactionNote	Cardholder logs supervisory guidance/notes to educate the AI Brain on future corporate expense preferences.	78,357	0.0000072 ETH **$0.0180 (1.8¢)**	**0.0000004 ETH $0.0010 (0.1¢)**
TetherGuardHook calibrateDynamicRadius	Vault autonomously recalculates and increases AI daily spending limit by up to 10% after 24h consecutive ratifications.	64,791	0.0000060 ETH **$0.0149 (1.5¢)**	**0.0000003 ETH $0.0008 (0.08¢)**
TetherGuardHook recordAIHeartbeat	AI agent periodically pings the vault to prevent the 48-hour Inactive AI Heartbeat watchdog timeout from tripping.	48,601	0.0000045 ETH **$0.0112 (1.1¢)**	**0.0000002 ETH $0.0006 (0.06¢)**
TetherGuardHook triggerDeadmanRecovery	Designated corporate guardian reclaims custody after 90 days of cardholder inactivity (emergency/medical recovery).	39,885	0.0000037 ETH **$0.0092 (0.9¢)**	**0.0000002 ETH $0.0005 (0.05¢)**
TecPaymaster validatePaymaster...	EntryPoint checks that cumulative AI session gas sponsorship does not breach the strict 0.005 ETH anti-griefing budget.	9,103	0.0000008 ETH **$0.0021 (0.2¢)**	**0.0000001 ETH $0.0001 (0.01¢)**
TecPaymaster postOp (Gas Accounting)	EntryPoint reconciles actual execution gas consumed and debits the corporate sponsor's prepaid gas escrow deposit.	64,843	0.0000060 ETH **$0.0149 (1.5¢)**	**0.0000003 ETH $0.0008 (0.08¢)**
TecAccount initialize (Vault Setup)	One-time vault initialization binding the Passkey root owner, TetherGuardHook policy, and SessionKeyValidator.	98,785	0.0000091 ETH **$0.0227 (2.3¢)**	**0.0000005 ETH $0.0012 (0.1¢)**

6.3 Multi-Chain Economic Analysis & Takeaways

- **Ethereum Mainnet Affordability:** Under live conditions (0.092 Gwei), every operation costs **$0.002 to $0.068 (a fraction of a cent to ~6¢)**.
- **Base Layer 2 Hyper-Efficiency:** On Base L2 (0.005 Gwei), fees are **18.4x cheaper**, with transactions costing **$0.0001 to $0.0037 (sub-cent)**.
- **Consortium Chains (WeBank / FISCO BCOS):** Native enterprise gas quota sponsorship enables **$0.00 zero-cost cardholder operations**.
- **Anti-Griefing Safety:** The 0.005 ETH session paymaster cap covers >180 autonomous userOps on Mainnet and >3,300 userOps on Base L2.

7. Integration Specifications & Reference

7.1 Shared Artifacts & Cross-Workstream Handoff

All compiled bytecode, ABIs, and local Anvil deployment addresses are continuously exported by export_shared_artifacts.py and mirrored across the development workspace:

- shared/contracts.json: Consumed directly by Member 2 (LangGraph AI Agent) and Member 3 (Next.js 14 Frontend).
- Desktop/contracts.json: Mirrored for local operator inspection and quick verification.

7.2 Architectural Glossary

Term	Definition & Architectural Significance
The Tether Radius	The daily discretionary spending velocity (in 8-decimal USD) granted to the autonomous AI Agent without human confirmation.
Breaking the Tether	The protocol for executing transactions exceeding the Tether Radius or outside the whitelisted asset tier, requiring biometric Passkey confirmation.
Biometric Grace Window	A 5-minute active window opened upon biometric authentication, allowing subsequent transactions to execute via simple Sign Approvals (Accept/Reject).
Vault Sovereignty	The immutable principle guaranteeing the Vault treasury is never frozen or penalized; only the AI Agent's autonomous radius is throttled.
Inactive AI Heartbeat	An on-chain liveness watchdog requiring periodic agent pings to prevent abandoned or compromised session keys from executing UserOps.
Corporate Dead-Man's Switch	A 90-day inactivity recovery mechanism allowing a designated corporate guardian to transfer vault ownership if the cardholder is incapacitated.

PRODUCTION READINESS & COMPETITION COMPLIANCE

Tec-C represents a mathematically provable, enterprise-grade architecture for autonomous on-chain wallets. With 100% passing tests (156/156 across 12 suites), zero unmitigated vulnerabilities, native RIP-7212 precompile integration, and complete alignment with Topic F (Agent Wallet) standards, Tec-C is fully prepared for evaluation by Tsinghua University PBCSF and WeBank.